

توسعه مبتنی بر مشخصات در سطح تولید

از نمونه شهودی تا واقعیت تولید: مشخصات، فرهنگ تیم، و شبکه ایمنی اعتماد صفر

مطالعه پیشنهادی: ۵۰ دقیقه شامل: جمع بندی کل دوره

فهرست مطالب

- مقدمه: توهم سرعت
- توسعه مبتنی بر مشخصات
- مشخصات خوب چه شکلی است
- قالب و اقتصاد توکن
- توسعه رفتارمحور
- دستورها کجا زندگی می کنند
- پنج حالت اجرا
- فرهنگ تیم و تحول فرایند
- سه لایه بازبین خودکار
- پایداری و خستگی تأیید
- توسعه اعتماد صفر
- جمع بندی دوره
- خودآزمایی

۱. مقدمه: توهم سرعت

«کدنویسی شهودی» به معنای «شهودی در تولید» نیست.

روال روزانه یک مهندس نرم افزار در یک سال گذشته کاملاً وارونه شده است. پیش تر زمان زیادی صرف کندوکاو در مستندات و رابطها می شد، و پس از پایان کد، تلاش چشمگیری برای اشکال زدایی و رفع فاصله میان کد کارکردی و

قصد اولیه لازم بود. امروز توسعه با سرعت سرسام‌آوری پیش می‌رود: تیم‌ها از عامل‌های کدنویسی استفاده می‌کنند که فقط متن پیشنهاد نمی‌دهند، بلکه واقعاً ابزار به کار می‌گیرند و کار اجرا می‌کنند. حس می‌کنید لشکری از کارآموز استخدام کرده‌اید که نه می‌خواهند و نه شکایت می‌کنند.

اما یک نکته هست

در حالی که سرعت به اوج رسیده، **توهم سرعت** واقعی است. نسبت اشکال به کد همچنان چالش است: چون هوش مصنوعی کد را بسیار سریع‌تر می‌نویسد، می‌تواند خطاهای بالقوه را هم با نرخی بی‌سابقه تولید کند. وقتی عامل دچار توهم می‌شود – یعنی مدل با اطمینان چیزی از خود می‌سازد که درست نیست – فقط یک اشکال نمی‌سازد؛ می‌تواند هزار خط منطق «هم‌حس اما کارکردشکسته» تولید کند.

و اگر بازبینان انسانی زیر سیل درخواست‌های ادغام تولیدشده غرق شوند، سرعت نوشتن بی‌ربط می‌شود. فرایند واقعاً سریع‌تر نشده؛ فقط انبوه بزرگ‌تری برای مرتب‌کردن بعدی ساخته‌اید.

جابه‌جایی گلوگاه – و فرصت پنهانش

چون پیاده‌سازی دیگر گلوگاه اصلی نیست، می‌توان هوش مصنوعی را به نوشتن **پوشش آزمونی جامع‌تر از آنچه هر انسانی در همان بازه می‌توانست بنویسد** گماشت. این راهی نیرومند و برنامه‌پذیر برای بالابردن اطمینان به کد است. افزون بر این، توان هوش مصنوعی بسیار فراتر از پیاده‌سازی می‌رود: در طراحی سامانه، نوشتن مشخصات، برنامه‌ریزی نقشه راه و تحلیل نتایج هم عالی است.

در محیط سازمانی، به این «حس‌وحال» می‌گوییم **توسعه با هوش مصنوعی عامل‌محور**. برخلاف هوش مصنوعی مولد استاندارد که مثل تکمیل خودکار هوشمند عمل می‌کند، هوش مصنوعی عامل‌محور مانند **عضوی ترکیبی از تیم** است: از مدل زبانی برای تولید استفاده می‌کند (مغز) و از ابزارها برای یکپارچه‌شدن در گردش کار (دست‌ها). می‌تواند استدلال کند، مشخصات یا پرونده آزمون بنویسد، با مرورگر رابط را ببازماید، و کد را ثبت و ادغام کند. اما وقتی توسعه از آزمایش فردی به تولید تیمی در مقیاس می‌رود، روشن می‌شود که **نوشتن هزار خط کد پیش از ناهار، همان انتشار نرم‌افزار نیست.**

۲. توسعه مبتنی بر مشخصات

در دنیای سنتی مهندسی نرم‌افزار، به توسعه‌دهندگان آموخته بودند «کد-اول» باشند: ایده‌ای مبهم منجر به بازکردن ویرایشگر و تایپ کردن می‌شد تا چیزی کار کند. اما در عصر هوش مصنوعی عامل‌محور، فعالیت روزانه به شدت جابه‌جا شده است. بیشتر وقت حالا صرف نوشتن **مشخصات باکیفیت** می‌شود: دستورهای فنی دقیقی که به هوش مصنوعی می‌گویند دقیقاً چه بسازد. در این گردش کار، نقش توسعه‌دهنده بیشتر **معمار فنی** است تا کدنویس سنتی.

بخش حیاتی ماجرا: کد دورریختنی است

اگر مشخصاتی محکم نوشته شود، کل کدپایه بارها و بارها بازتولیدشدنی است. حتی می‌توان به عامل گفت کل پروژه را در یک بعدازظهر از یک زبان به زبان دیگر ببرد.

و چون کد دورریختنی است، آن دلبستگی عاطفی قدیمی وجود ندارد. وقتی دوازده ساعت صرف اشکال‌زدایی یک نقطه‌ویرگول نکرده‌اید، از دورانداختن و شروع دوباره – وقتی نیازمندی‌ها عوض می‌شوند – هم نمی‌ترسید.

عامل‌های کدنویسی با استفاده از مدل زبانی به‌عنوان «مغز» برای استدلال و ابزارها به‌عنوان «دست‌ها» برای اجرا کار می‌کنند. اگر به مغزی «حس‌وحال» بدهید به‌جای «نقشه»، حدس می‌زند. و در نرم‌افزار سازمانی، حدس‌زدن همان چیزی است که حادثه «عامل یاغی» را می‌سازد.

۳. مشخصات خوب چه شکلی است

مشخصات خوب یک ستاره شمالی معماری است. از «پاره‌پاره‌شدن زمینه» جلوگیری می‌کند – معادل دیجیتالی بازی «تلفن»، جایی که هوش مصنوعی رشته ماجرا را گم می‌کند چون دارد به عکس‌های قدیمی فایل‌ها نگاه می‌کند. می‌توان از هوش مصنوعی برای پالایش مشخصات استفاده کرد، عملاً به‌عنوان هم‌نویسنده یا ویراستار و بازبین. معمولاً مشخصات درون خود کدپایه ذخیره می‌شود، مثلاً به‌صورت فایلی مارک‌داون یا YAML در پوشه specs/، و منبع حقیقت برای هم انسان و هم هوش مصنوعی است.

چهار بخش مشخصات تولید یک پروژه تازه

1. طراحی فنی کامل: فقط نگویید «صفحه ورود بساز». تجزیه‌اش کنید: نیازمندی‌ها، طرح‌واره پایگاه داده (ساختار داده‌ها) و مشخصات رابط‌ها (قراردادهایی که اجازه می‌دهند بخش‌های مختلف نرم‌افزار با هم حرف بزنند).
2. کمک بصری: نمودارها، و فهرستی از ابزارها و کتابخانه‌های مشخص همراه با شماره نسخه.
3. اطلاعات زمینه‌ای: «چرا» را پشت «چه» به عامل بدهید؛ این کمک می‌کند رو به جلو فکر کند و گام‌هایی را که احتمالاً لازم خواهید داشت هم بشناسد.
4. سناریوها: خوب چه شکلی است، بد چه شکلی است، و حالت‌های مرزی کدام‌اند.

نکته عملی

طراحی‌های فنی را جایی بنویسید که دیگران بتوانند بخوانند و بازبینی کنند. این حالا مهم‌تر از همیشه است: ترجیح می‌دهید انسانی نقص منطقی طرح شما را بگیرد، تا اینکه صبر کنید هوش مصنوعی هزاران خط کد شکسته تولید کند. پس از بازبینی، سند را به مارک‌داون تبدیل و در پوشه `specs/` فضای کاری‌تان بگذارید.

۴. قالب و اقتصاد توکن

پژوهش‌ها نشان می‌دهند عامل‌های مدل‌زبانی به نحوه قالب‌بندی دستورها حساسیت شدیدی دارند، تا حدی که فایل‌های مارک‌داون عمومی و بهینه‌نشده می‌توانند افت عملکرد چشمگیری بسازند. راهبرد پیشنهادی، رویکردی ترکیبی است: از سرتیترهای تمیز مارک‌داون برای لنگرانداختن توجه مدل استفاده کنید، اما برای هر پیکربندی ساختارمند یا طرح‌واره داده‌ای با عمق تودرتویی بیش از سه، به YAML سوئیچ کنید.

قالب	دقت تجزیه در ساختارهای عمیقاً تودرتو
YAML	بالاترین دقت
JSON	متوسط
XML	پایین‌ترین

با رندرکردن مشخصات عمیقاً تودرتو در YAML و نگه‌داشتن دستورهای روایی در مارک‌داون، مالیات قالب را دور می‌زنید؛ همان هزینه استدلالی که ورودی‌های سنگین تحمیل می‌کنند.

توکن یک قید فیزیکی است

مدل‌های زبانی ساختار داده را تفسیر نمی‌کنند؛ متن نشانه‌گذاری‌شده را پردازش می‌کنند. هر نویسه‌ای که می‌فرستید به نشانه‌ها شکسته می‌شود و هر نشانه بودجه، زمان و ظرفیت زمینه مصرف می‌کند. هر فاصله غیرضروری در یک بلوک عمیقاً تودرتو و هر دستور تکراری، چرخه پردازش و ظرفیت توجه را در همان حلقه‌های چندنوبتی می‌بلعد که عامل در آن‌ها برنامه را می‌سازد، می‌آزماید و ویرایش می‌کند.

پس با پوشه `specs/` نه مثل مستندات، بلکه مثل یک مجموعه‌دستور کامپایل‌شده و کم‌چرب رفتار کنید.

۵. توسعه رفتارمحور

مشخصات رفتارمحور، ابزار نهایی تبدیل ایده‌های مبهم انسانی به طراحی معماری دقیقی است که عامل بتواند بدون حدس‌زدن بسازدش. در هسته‌اش، روشی است که با زبان طبیعی ساده و ساختارمند توصیف می‌کند سامانه از دید کاربر دقیقاً چگونه باید رفتار کند – پیش از آنکه هیچ کدی نوشته شود.

این مشخصات از نحوی استاندارد به نام **گرکین** استفاده می‌کند که بر قالبی ساده و اعلانی تکیه دارد: **سناریو / با فرض / وقتی / آنگاه**. این قالب مدل را وادار می‌کند به صورت **موقعیت** ← **کنش** ← **نتیجه** فکر کند، و همین کدنویسی شهودی را کاملاً حذف و عامل را روی ریلی سخت‌گیرانه نگه می‌دارد.

```
Scenario: Retry a failed payment within the allowed window
  Given a payment with status "failed" and 2 previous attempts
  And the failure reason is "network_timeout"
  When the retry job runs within 24 hours of the original attempt
  Then a new attempt is created with attempt_number 3
  And the original transaction id is preserved
  And no duplicate charge is issued
```

```
Scenario: Refuse retry after the attempt limit
  Given a payment with status "failed" and 3 previous attempts
  When the retry job runs
  Then no new attempt is created
  And the payment is moved to status "requires_manual_review"
```

سه کار با یک نوشته

این متن هم‌زمان مشخصات است، هم پروندهٔ آزمون، و هم دستور دقیق برای عامل. همین سه‌کاره بودن است که توسعهٔ رفتارمحور را در عصر عامل‌ها دوباره ارزشمند کرده است.

۶. دستورها کجا زندگی می‌کنند

برای عمل به توسعهٔ مبتنی بر مشخصات، باید فهمید ابزارهای کدنویسی چگونه دستورها را مصرف می‌کنند. دستورها در یک جا نوشته نمی‌شوند. ریختن یک سند طراحی صد صفحه‌ای مستقیم در پنجرهٔ گفت‌وگو، بودجهٔ زمینهٔ کوتاه‌مدت را به سرعت تمام می‌کند، تأخیر را بالا می‌برد و زمینه را پاره‌پاره می‌کند.

جایگاه	ماهیت	چه چیزی آنجا می‌رود
رابط گفت‌وگو	کوتاه‌عمر، ویژه نشست	فقط برای هماهنگی سطح بالا و حلقه بازخورد فوری. برای نمونه: «طراحی موجود در specs/payment_retry.md را بازبینی کن و آزمون‌های واحد شکست‌خورده تعریف‌شده در سناریوی ۳ را بساز.»
پوشه مشخصات	ویژه کار، در کنترل نسخه	پوشه‌ای ایستا که مستقیم در مخزن ثبت می‌شود و طراحی فنی، سناریوهای رفتارمحور، قرارداد رابط‌ها و طرح‌واره‌های ساختارمند را نگه می‌دارد. عامل این دایرکتوری را پویا نمایه می‌کند و بدون چپاندن دستی درخواست، کد را می‌سازد و راستی‌آزمایی می‌کند.
مهارت‌های عامل	قابل استفاده مجدد، رفتارمحور	فایل‌های ساختارمندی که گردش کارهای تخصصی و محرک‌دار را حمل می‌کنند و باید در دایرکتوری مشخصی قرار بگیرند تا شناسایی شوند. آن‌ها عادت‌های مهندسی تکرارشونده را می‌آموزند – مثل نگه‌داری خودکار فهرست تغییرات وقتی تغییری در کد تشخیص داده می‌شود. این پوشه می‌تواند دارایی داده یا اسکریپت هم داشته باشد.
درخواست‌های سامانه	سراسری، هویت‌محور	جایی که هوش مصنوعی دی‌ان‌ای مهندسی شما را می‌آموزد. فایل‌های زمینه سلسله‌مراتبی خوانده و به هم چسبانده می‌شوند: پرو فایل سراسری در دایرکتوری خانگی که شخصیت و سبک پیش‌فرض را تعریف می‌کند؛ پیکربندی مشترک چندابزاری که از پاره‌پاره‌شدن دستورها میان چند کلاینت جلوگیری می‌کند؛ و مشخصات پروژه در ریشه مخزن که بالاترین اولویت را دارد.

۷. پنج حالت اجرا

فقط یک راه برای تبدیل مشخصات به کد وجود ندارد. هر حالت، ذهنیت متفاوتی می‌خواهد.

۱. تولید پروژه – معمار

- بدون حالت بی‌محابا: صریحاً به عامل بگویید فوری کد نزنند. اول باید ساختار پوشه‌ها و پشتۀ فناوری را برای تأیید پیشنهاد بدهد.
- اطمینان حاصل کنید که درخواست شامل تولید **آزمون، مستندات و گزارش‌برداری** است – گزارش‌برداری همان «جعبۀ سیاه» دیجیتالی است که ثبت می‌کند برنامه چه می‌کند.
- برای هر کتابخانه **شمارۀ نسخه** بدهید. بدون آن، عامل ممکن است نسخه قدیمی‌تری پیشنهاد دهد، چون تاریخ پایان دادۀ آموزشی‌اش در گذشته بوده است.

نکته نسخه‌ها

گاهی عامل نسخه‌های پایین‌تری از ابزارها، کتابخانه‌ها یا مدل‌های موجود را پیشنهاد می‌دهد، چون مدل زیرین تا زمان مشخصی آموزش دیده است. این را می‌توان با افزودن مستندات به‌روز در پوشۀ مشخصات، یا ذکر این اطلاعات در مهارت‌ها و درخواست‌های پروفایل پیشگیری کرد. به یاد داشته باشید عامل‌ها به‌آسانی به دادۀ آموزشی‌شان برمی‌گردند؛ پس شماره‌نسخه‌های پیشنهادی باید همیشه دوباره واریسی شوند.

۲. تولید قابلیت – سازنده

در این حالت، قابلیت‌ها روی کدپایۀ موجود پیاده می‌شوند. از عامل بخواهید **سبک موجود را رعایت کند**، شامل الگوهای نام‌گذاری و شیوۀ مدیریت خطا در کد. وقتی چند فایل ویرایش می‌شود، تغییرها باید دستی تأیید شوند. دیدن «تفاوت‌ها» – فهرستی که دقیقاً نشان می‌دهد چه خط‌هایی اضافه یا حذف می‌شود – درون ویرایشگر اهمیت دارد.

۳. رفع اشکال – متخصص جرم‌شناسی

وقتی چیزی می‌شکند، حالت جرم‌شناسی لازم است. هدف، تحلیل علت ریشه‌ای و ترمیم جراحی است. از **درخواست علامت‌محور** («دکمه کار نمی‌کند») به **درخواست شاهدمحور** بروید («گزارش‌هایی که با این فرمان گرفتم خطای ۴۰۳ نشان می‌دهند»). سپس جریان را توضیح دهید: «درخواست به متعادل‌کنندۀ بار می‌رسد ← لایۀ احراز هویت سرایند را حذف می‌کند ← غلاف شکست می‌خورد.»

- همیشه اول یک **آزمون واحد شکست‌خورده** یا فرمان بازتولید بخواهید تا اشکال را بازسازی کند، و آن پرونده را در کدپایه نگه دارید تا اشکال برنگردد.
- قید سختی بگذارید که عامل **فقط** علت ریشه‌ای را درست کند. کد بی‌ربط نباید «تمیزکاری» شود، چون فرایند بازبینی را پیچیده می‌کند.
- تغییر نام متغیرها پذیرفتنی است، اما باید کاری **جداگانه** باشد، نه بخشی از رفع اشکال.

مرورگر داخلی و آزمون سرتاسری

برخی محیط‌های عامل‌محور مرورگری داخلی دارند که به عامل اجازه می‌دهد خودگردان برنامه محلی را اجرا کند، با رابط زنده تعامل کند و اصلاح‌های بصری را در زمان واقعی راستی‌آزمایی کند. نکته امنیتی مهم این است که این زیرعامل درون نمایه مرورگری کاملاً ایزوله و جعبه‌ش‌مانند اجرا می‌شود که ورودهای فعال یا نشست‌های شخصی را نمی‌بیند – عملاً محیطی ناشناس و تمیز – و همین از نشت زمینه و عملیات تصادفی روی حساب واقعی جلوگیری می‌کند. پس درخواست‌های اشکال‌زدایی می‌توانند بسیار فراتر از تحلیل ایستای کد بروند.

۴. نوشتن مستندات – نویسنده

در توسعه مبتنی بر مشخصات، **مستندات منبع حقیقت است**. اگر مستندات و کد هم‌گام نباشند، هوش مصنوعی شروع به توهم می‌کند. در مهارت‌های عامل مشخص کنید که دستورهای فایل راهنما و فهرست تغییرات همیشه باید نگه‌داری شوند. از قالب‌های استاندارد مستندسازی درون‌کد استفاده کنید؛ این‌ها روش‌های ساختارمند نوشتن توضیحات‌اند که به هوش مصنوعی (و انسان) کمک می‌کنند بفهمند یک تابع دقیقاً چه می‌کند، بدون خواندن هر خط منطق.

۵. مهندسی داده – کتابدار

هنگام پرس‌وجوی جدول‌ها یا جابه‌جایی فایل‌ها، نقش شما مهندس داده است. از افزونه‌های ویرایشگر برای دسترسی مستقیم به داده ابری استفاده کنید، و از عامل بخواهید همیشه پرس‌وجو یا فرمان دقیقی را که برای تولید خروجی به کار برده نشان بدهد.

۸. فرهنگ تیم و تحول فرایند

کار با عامل‌های کدنویسی مدرن نیازمند تغییر در تفکر و فرهنگ تیم است. چسبیدن به فرایندهای قدیمی هنگام استفاده از ابزارهای مدرن، مثل نصب موتور جت روی درشکه است؛ این فناوری را نمی‌توان به گردش‌کاری بیست‌ساله پیچ کرد و انتظار پرواز داشت.

سه دسته شکست فرایندی

- **تعارض‌های ادغام:** چند توسعه‌دهنده ظرف یک ساعت روی یک فایل فرود می‌آیند.
- **گره‌خوردگی بازبینی:** درخواست ادغامی غول‌آسا به عروسک روسی زیردرخواست‌ها بدل می‌شود. اولی بدون دومی ادغام نمی‌شود، دومی به سومی نیاز دارد، و سومی پشت بازبینی در منطقه زمانی دیگری گیر کرده است. برخی تغییرها تأیید می‌شوند در حالی که تغییرهای مرتبط منتظر بازبینی‌اند، و همین تعارض‌های بیشتری می‌زاید.

- **پاره‌پاره‌شدن زمینه:** در غیاب یک توسعه‌دهنده، هم‌تیمی متغیری را در فایل مشترک تغییر نام می‌دهد؛ عامل که به عکسی قدیمی استناد می‌کند، کدی می‌سازد که تابعی دیگر موجود را صدا می‌زند.

پنج راهبرد یکپارچگی پرسرعت

1. **خلاصه و ارزیابی مخاطره بسته‌بندی‌شده:** هر درخواست ادغام باید نمای تولیدشده‌ای از آنچه تغییر کرده، نقاط محتمل شکست و ارزیابی مخاطره داشته باشد – به صورت فایلی مارک‌داون یا توضیح مفصل ثبت. این کمک می‌کند بازبین انسانی به جای گم‌شدن میان خط‌ها، روی اثر معماری تمرکز کند.
2. **بازتعریف مالکیت:** تمرکز بازبینی انسانی را از ایرادگیری سبکی روی کد دورریختنی عامل‌نوشته، به تضمین یکپارچگی نقشه‌های معماری منتقل کنید. دغدغه‌های سبکی با ابزارهای خودکار یکپارچه‌سازی مثل واریسی‌گرهای مشترک یا کتاب‌سبک‌های ویژه فضای کاری حل می‌شوند.
3. **تأیید مشروط:** برای حذف تأخیرهای دوازده‌ساعته در تیم‌های چندمنطقه‌ای، بازبین درخواست ادغام را مشروط به گذراندن همهٔ آزمون‌های خودکار تأیید می‌کند؛ اگر آزمون‌ها سبز شدند، کد خودکار ادغام می‌شود.
4. **تعریف فرهنگ بدون سرزنش:** در محیط‌های پرسرعت، کسی که بیشترین کد را تولید می‌کند اغلب قربانی سرزنش اشکال‌ها یا تعارض‌های ادغام می‌شود. مفید است دربارهٔ نسبت‌دادن این مسائل به **فرایند یکپارچگی شکسته** به جای فرد استفاده‌کننده از عامل گفت‌وگو کنید.
5. **بازبینی کد به دست عامل:** می‌توانید مهارتی بسازید که بازبینی را برایتان انجام دهد، و حتی مهارتی که به بازبینی‌ها پاسخ بدهد. این را می‌توان با گردش کارهای خودکار مخزن به طور کامل خودکار کرد.

و یک پرسش باز برای تیم

اگر می‌توانید با جوخه‌ای از عامل‌ها کار کنید، آیا اصلاً لازم است به صورت تیمی کار کنید؟ اگر پاسخ مثبت است، راه‌هایی برای تقسیم کار بیابید که اعضای تیم به ندرت به فایل‌های یکسان دست بزنند – مثلاً مالکیت روشن بر رابط‌ها در برابر تجربهٔ کاربری. وقتی هم‌پوشانی ناگزیر است، «مالک بخش» تعیین‌شده هماهنگی نهایی را انجام دهد.

نمونه مهارت بازبینی کد

Act as a Senior Software Engineer and Security Researcher.

Review the provided PR or diff using these strict criteria:

1. Critical Vulnerabilities: hardcoded secrets (API keys), SQL injection, XSS, or broken authentication.
2. Logic & Efficiency: off-by-one errors, infinite loops, redundant API calls.
3. Readability: better naming conventions, break down mega-functions into smaller pieces.
4. Edge Cases: What happens if the input is null? What if the network fails?

Output Format:

- Description: what is this PR doing? Explain in detail.

ISSUES:

- Critical: (stop-ship issues)
- Warnings: (code smells or style issues)
- Best Practices: (specific lines to refactor for performance)
- Quick Win: (one-sentence summary of the biggest improvement)

When there are no issues, return the description and "LGTM".

۹. سه لایه بازبین خودکار

می‌توانید درخواست بازبینی عالی بنویسید. اما چه کسی آن را روی هر درخواست ادغام و هر پویش شبانه اجرا می‌کند، بدون اینکه انسانی دکمه را فشار دهد؟ گام بعدی، استقرار این مهارت‌ها به‌عنوان **عوامل‌های تحلیل پیوسته کد** است: سرویس‌هایی که مخزن را می‌پایند، به رویدادها واکنش نشان می‌دهند و یافته‌ها را بدون درخواست کسی پست می‌کنند. آن‌ها چیزهایی را می‌گیرند که انسان خسته عصر جمعه از دست می‌دهد: وابستگی‌ای با آسیب‌پذیری تازه‌کشف‌شده، یا یادداشتی از شش ماه پیش که بی‌سروصدا به شکاف امنیتی بدل شده است.

لایه	چیست	موازنه
۱ – مدیریت شده	مسیر آماده: سرویسی را روی سازمان مخزن فعال می‌کنید و هر درخواست ادغام بازبینی می‌شود که دربارهٔ سبک، اشکال و امنیت نظر می‌دهد.	هیچ درخواستی نمی‌نویسید و هیچ زیرساختی مدیریت نمی‌کنید. اما نظرهای بازبینی فروشنده را می‌گیرید نه نظرهای خودتان، و بازبین عمومی چیزی را که برای تیمی با سبک خانگی سخت‌گیرانه یا نمای مخاطرهٔ حوزه‌ای اهمیت دارد از دست می‌دهد.
۲ – ترکیبی	مهارت بازبینی خودتان را می‌نویسید، در مخزن ثبت می‌کنید، و آن را از کنشی در یکپارچه‌سازی پیوسته اجرا می‌کنید که خط فرمان عامل را در حالت غیرتعاملی می‌راند و نتیجه را به‌عنوان نظر پست می‌کند.	مسیر میانی و نقطهٔ شروع درست برای بیشتر تیم‌ها. زمان اجرا مال ارائه‌دهندهٔ یکپارچه‌سازی شماست؛ اما درخواست‌ها، انتخاب مدل، جعبه‌شن و معیارهای بازبینی مال شماست.
۳ – سفارشی	بازبین را به‌عنوان عاملی کامل می‌سازید، روی زمان اجرای مدیریت شده با نشست و حافظهٔ ماندگار مستقر می‌کنید، و به رویدادهای مخزن وصلش می‌کنید.	وقتی درست است که بازبین باید زمینه را در یک بازسازی چنددرخواستی نگه دارد، کاری مثل «این سرویس را برای انحراف انطباق ممیزی کن» را به ده‌ها زیرکار بشکند، یا با عامل‌های دیگر هماهنگ شود. اما ارزیابی، رصدپذیری، هزینه و نوبت‌کاری هنگام خرابی هم مال شماست.

سه پرسش که لایه را تعیین می‌کنند

۱. معیار بازبینی‌تان چقدر ویژه است؟ عمومی ← لایهٔ ۱. ویژهٔ تیم یا مخزن ← لایهٔ ۲ یا ۳.
۲. آیا عامل باید چیزی را میان اجراها به یاد بسپارد؟ نه ← لایهٔ ۱ یا ۲. بله (حافظهٔ کدپایه، زمینهٔ چنددرخواستی) ← لایهٔ ۳.
۳. بدترین حالت چیست اگر اشتباه کند؟ نظری پرحرف ← هر لایه‌ای. پس‌رفتی که ادغام شود یا رازی که نشد کند ← لایهٔ ۳، با سرور سیاست پیش از هر فراخوان ابزار.

پایین‌ترین لایه‌ای را بردارید که آنچه اهمیت دارد را می‌گیرد. بیشتر تیم‌ها لایه خود را همان لحظه‌ای کشف می‌کنند که بازبین مدیریت‌شده چیز خاصی را از دست می‌دهد. نمونه واقعی: تیمی در یک شرکت مالی از لایه ۱ شروع کرد و دید بازبین انطباقش چیزهایی را علامت می‌زند که حساب‌رسان قبلاً تأیید کرده بودند، در حالی که تنها الگوی مهم – اطلاعات هویتی پوشانده‌نشده در گزارش‌ها – را از دست می‌داد. یک مهارت چهل‌خطی واریسی انطباق، وصل‌شده به گردش‌کار خودکار مخزن (لایه ۲)، ظرف یک هفته هشدارهای کاذب را به شدت کاهش داد. لایه ۳ هنوز لازم نشده است.

لایه ۳ در مقیاس کامل: درک گرافی کد

بازبین سفارشی از یک عامل ساده که تفاوت‌ها را می‌خواند فراتر می‌رود. روی کدپایه‌ای با ده‌ها میلیون خط، بارکردن کد به شکل متن تخت در پنجره زمینه جا کم می‌آورد، و بازیابی استاندارد ساختاری را حذف می‌کند که کد را خوانا می‌سازد: کلاس به فایلی تعلق دارد، و فراخوان تابعی به سند نیازمندی‌ای که ده سال پیش نوشته شده ردیابی می‌شود. الگویی که در بزرگ‌ترین نوسازی‌های کد قدیمی پدیدار شده، ساختن عامل روی یک **گراف دانش** است: کد، مستندات، تیکت‌ها و اسناد طراحی را در پایگاه‌داده‌ای گرافی می‌ریزید و سپس عامل‌ها سه شیوه بازیابی را ترکیب می‌کنند:

- **پیمایش گراف** برای پرسش‌های ساختاری: «هر تابعی که به طور متعدي فلان تابع را صدا می‌زند.»
- **جست‌وجوی برداری** برای پرسش‌های معنایی: «کدی پیدا کن که کاری را می‌کند که این پاراگراف توصیف می‌کند.»
- **جست‌وجوی تمام‌متن** برای تطبیق دقیق شناسه‌ها.

ترکیب این سه به پرسش «اگر این را عوض کنم چه چیزی می‌شکند؟» با نقشه اثر دقیق پاسخ می‌دهد، نه با حدسی مطمئن.

نیمه دوم ماجرا **تجزیه** است. یک عامل که به او بگویید «این ماژول را بازسازی کن» شکست می‌خورد. همان کار را روی خط لوله زیرعاملی تقسیم کنید – عامل جست‌وجو که گراف را می‌کاود، عامل داستان که نیازمندی‌ها را می‌گیرد، عامل اثر که عوارض جانبی را پیش‌بینی می‌کند، عامل تجزیه کار که واحدهای اتمی می‌سازد، و تازه بعد عامل کدنویسی – و کار مدیریت‌پذیر می‌شود. در کدپایه‌های میلیون‌خطی گزارش شده که کار بازسازی معادل از دو هفته به چند ساعت رسیده است.

۱۰. پایداری و خستگی تأیید

پدیده‌های تازه

پژوهش‌ها نشان می‌دهند کاربران پرکار هوش مصنوعی به مراتب بیشتر از غیرکاربران در معرض فرسودگی شدید قرار دارند. زیر جریان مداوم تأییدهای خرد – بهبود یک خط، تنظیم یک فراخوان ابزار – توسعه‌دهنده به صورت بازتابی روی «تأیید» کلیک می‌کند. این شکلی از خستگی کم‌شدت است که در آن تیم فقط برای همپا ماندن با سرعت ماشین، از واریسی کارش دست می‌کشد – و شما ریسک می‌کنید که توسعه‌دهندگان توجه به جزئیات را از دست بدهند.

برای محافظت از تیم، از نظارت مداوم به مرزهای ساختارمند بروید:

- **ساعت‌های آرام دیجیتالی:** مرزهایی بگذارید تا درخواست‌های تأیید به عصرها و آخر هفته‌ها نشت نکنند.
- **جلسه‌های بینش عامل:** جلسه‌های هفتگی برگزار کنید که در آن‌ها توسعه‌دهندگان الگوهای شناسایی‌شده به دست همتای هوشمندشان را به اشتراک می‌گذارند، و کشف‌های منفرد به دانش سازمانی مشترک بدل می‌شود.

۱۱. توسعه اعتماد صفر: ساختن شبکه ایمنی

داستان واقعی پنجاه ایمیل

هنگام یک به‌روزرسانی معمولی کد، توان و مرزهای مرورگر داخلی یک محیط عامل‌محور آشکار شد. این قابلیت به عامل اجازه می‌دهد بدون نیاز به اعتبارنامه ورود با برنامه‌های در حال توسعه تعامل کند و برای آزمون تجربه کاربری بی‌نظیر است. اما در **حالت تأیید خودکار**، می‌تواند سریع‌تر از فکر انسان عمل کند.

درخواست ساده‌ای برای ساختن یک دکمه، زنجیره واکنش غیرمنتظره‌ای را راه انداخت: عامل مرورگر خودگردان روی دکمه تازه کلیک کرد که برای عامل ایمیل در نظر گرفته شده بود. چون نشانی مشخصی تعریف نشده بود، عامل توهم کرد و به عاملی قدیمی و منسوخ بدون هیچ حفاظ ایمیلی وصل شد. نتیجه؟ **پنجاه همکار ایمیل‌های جعلی پر از محتوای توهمی دریافت کردند.**

درس این حادثه

این رویداد **مخاطرهٔ توهم زمینه** را برجسته کرد: وقتی هوش مصنوعی دادهٔ کافی ندارد، گاهی شکافها را با هر رشته‌ای که در زمینه‌اش موجود است پر می‌کند، از جمله اطلاعات حساسی مثل نشانی‌های ایمیل سخت‌کدشده یا نشانی‌های خصوصی.

ممکن است اگر فقط یک ایمیل باشد جزئی به‌نظر برسد. اما به آنچه عامل انجام می‌داد فکر کنید: داشت دستورش را با داده‌ای که در اختیار داشت انجام می‌داد، **بدون هیچ واریسی‌ای بر اینکه آیا باید این کار را بکند یا نه**. این هستهٔ مخاطره در سامانه‌های خودگردان است. حفاظها اختیاری نیستند؛ همان چیزی‌اند که نمی‌گذارند ابزاری مفید به ابزاری غیرقابل‌پیش‌بینی بدل شود.

پارادوکس حفاظ

با هل‌دادن مرزهای هوش مصنوعی عامل‌محور به پارادوکسی برمی‌خوریم: عامل‌ها باید آن‌قدر خودگردان باشند که مسائل پیچیده را حل کنند، اما نمی‌توان ریسک یاغی‌شدنشان را در محیط سازمانی پذیرفت. عاملی را تصور کنید که مأمور «حل اختلاف‌های مشتری» است: برای مؤثر بودن به دادهٔ مشتری، ابزار ایمیل و سامانه‌های داخلی نیاز دارد. اما چالش این است که مطمئن شویم تصادفی کل پایگاه داده را ایمیل نمی‌کند یا کد اختصاصی را به اشتراک نمی‌گذارد.

چرا سخت‌کدکردن قید در درخواست سامانه شکننده است

عامل‌های خودگردان را مدل‌هایی می‌رانند که **احتمالاتی‌اند، نه قطعی**. زمینه‌ها سرریز می‌کنند و می‌شود عامل را با تزریق درخواست «قانع» کرد که قواعد را دور بزند. برای ساخت سکوهایی سطح تولید، به حکمرانی **بیرونی و دست‌نیافتنی** نیاز است.

پنج لایهٔ شبکهٔ ایمنی

۱. جعبه‌شن

فراتر از پاک‌سازی رشته‌ها، امنیت واقعی محیط اجرای محدود می‌خواهد. حتی با پالایش دقیق خروجی، مدل ممکن است کدی تولید کند که از نظر نحوی معتبر اما از نظر منطقی مخرب است. با اجرای کارهای عامل‌محور درون ظرف‌های زودگذر و کم‌امتیاز که از شبکهٔ اصلی و فایل‌سیستم حساس ایزوله‌اند، **شعاع انفجاری** می‌سازید که از زیرساخت اصلی محافظت می‌کند. در این مدل، اگر عامل فریب بخورد و فرمانی مخرب اجرا کند، آسیب به نمونه‌ای دورریختنی محدود می‌ماند که می‌توان بی‌عواقب پاکش کرد.

در برخی محیط‌ها این شبکه ایمنی با یک کلید در تنظیمات فعال می‌شود. اگر جعبه‌شنی قابل حمل و ابری برای تیم لازم دارید، فضای کاری عامل را در ظرف بگذارید: فایل ظرف سفارشی بنویسید، اعتبارنامه ابری محدود تزریق کنید، و ابزار را وادار کنید کاملاً درون ظرف اجرا شود. در هر دو مدل، اگر عامل فریب بخورد، به خطای مجوز سختی در سطح هسته برمی‌خورد و سامانه میزبان کاملاً دست‌نخورده می‌ماند.

۲. انسان در حلقه

هرچند خودکارسازی هدف است، عملیات پرمخاطره به پروتکل انسان-در-حلقه به‌عنوان ایمنی نهایی نیاز دارند. این یعنی پیاده‌سازی دروازه‌های «وارسی» برای کنش‌هایی که نمای مخاطره مشخصی دارند: انتشار کد در تولید، تغییر طرح‌واره پایگاه داده، یا آغاز تراکنش مالی. با ارائه قصد پاک‌شده عامل به ناظر انسانی برای تأیید دستی، سرعت هوش مصنوعی با قضاوت ظریف توسعه‌دهنده متوازن می‌شود. این تضمین می‌کند که در حالی که عامل کار سنگین را انجام می‌دهد، مسئولیت نهایی یکپارچگی معماری محکم در دست انسان می‌ماند.

۳. پوشش آزمون تولیدشده با هوش مصنوعی

جهش کد تولیدشده، جابه‌جایی از آزمون دستی به پوشش آزمون تولیدشده با هوش مصنوعی را ضروری می‌کند. در محیطی پرسرعت، «توسعه آزمون‌محور» با گماشتن ماشین به نوشتن همان آزمون‌هایی که خروجی خودش را اعتبارسنجی می‌کنند به واقعیت بدل می‌شود. این فرایند یعنی وادارکردن عامل به تولید یک آزمون واحد شکست‌خورده یا فرمان بازتولید پیش از هر تلاشی برای اصلاح. با جاسازی این آزمون‌ها در کدپایه، هر تکرار سریع با مجموعه‌ای از وارسی‌های راستی‌آزمایی‌پذیر پشتیبانی می‌شود.

۴. ارزیابی

چرا برای کدی که از مدل‌ها استفاده می‌کند به وارسی کیفیت ویژه نیاز داریم؟ آزمون‌های سنتی برای سامانه‌هایی که خروجی‌شان **تولید** می‌شود و نه **محاسبه**، ناکافی‌اند. عامل – یا هر جزء مدل‌محور دیگری – می‌تواند صد آزمون واحد را روی ابزارهایش بگذراند و همچنان به‌شکل تماشایی شکست بخورد: با انتخاب ابزار اشتباه، بازنویسی بد یک پاسخ حیاتی، یا توهم یک واقعیت.

آزمون در برابر ارزیابی

آزمون واحد می‌پرسد «آیا تابع مقدار درست را برگرداند؟» – پاسخی دوتایی. ارزیابی می‌پرسد «آیا رفتار عامل دست‌کم به‌خوبی مبناست؟» – نمره‌ای از داور مدل‌زبانی، وارسی مسیری که تنوع ترتیب فراخوان ابزار را تحمل می‌کند، و دروازه‌ای که وقتی کیفیت زیر حاشیه‌ای قابل‌پیکربندی بیفتد فعال می‌شود، نه وقتی ادعایی نقض شود.

آزمون‌ها پس‌رفت قطعی را می‌گیرند؛ ارزیابی انحراف رفتاری را. و حاشیه خطا نقصی نیست که باید حذف شود؛ ویژگی ذاتی مدل است و راهبرد آزمون باید با آن کنار بیاید.

۵. سرور سیاست

سرور سیاست ترکیبی کنش‌ها را پیش از رسیدن به سامانه‌های بیرونی رهگیری می‌کند و در دو لایه کار می‌کند:

- **دروازه ساختاری (چراغ راهنما):** قواعد قطعی بر پایه نقش و محیط. واری‌هایی سریع و دوتایی – مثلاً نقش «بیننده» نمی‌تواند از ابزار ارسال ایمیل استفاده کند. این لایه بدون پرسیدن از هیچ مدلی، از نقض معماری جلوگیری می‌کند.
- **دروازه معنایی (داور هوشمند):** مدلی ثانویه و تخصصی که قصد و محتوای کنش پیشنهادی را در برابر راهنماهای حریم خصوصی به زبان طبیعی بازرسی می‌کند. این برای وقتی است که **ابزار مجاز است اما نحوه استفاده سیاست را نقض می‌کند:** مدیر می‌تواند ایمیل بفرستد، اما نباید اطلاعات هویتی پوشانده نشده بفرستد. همین‌جاست که قواعد ساختاری شکست می‌خورند، چون نمی‌توان هر نشت ممکن را با عبارت باقاعده گرفت.

```
environments:
  localhost:
    blocked_tools:
      - send_email

roles:
  viewer:
    allowed_tools:
      - list_files
      - read_file
```

جریان اجرا هنگام تصمیم‌عامل به استفاده از ابزار رهگیری می‌شود:

1. **واری ساختاری:** آیا این ابزار برای این نقش و محیط مجاز است؟
2. **واری معنایی:** آیا آرگومان‌ها امن‌اند؟ (برای نمونه، نشانی ایمیل پوشانده نشده نقض محسوب می‌شود).
3. **اجرا:** اگر هر دو گذشتند، ابزار اجرا می‌شود. وگرنه پیام «نقض سیاست» به عامل برمی‌گردد تا خودش را اصلاح کند یا با ظرافت شکست بخورد.

این کار شبکه ایمنی‌ای می‌سازد که **منطق اجرا را از منطق حکمرانی جدا می‌کند** – تفکیک مسئولیتی حیاتی برای نرم‌افزار سازمانی.

بهداشت زمینه و پاک‌سازی درخواست

برای مهار مخاطرهٔ توهم زمینه، بهداشت زمینه را با میان‌افزاری پیاده کنید که اطلاعات هویتی را می‌پوشاند و جانشین تزریق می‌کند. با جایگزین کردن اطلاعات شناسایی‌پذیر با جانشین‌های عمومی در قالب‌ها، مطمئن می‌شوید عامل روی دادهٔ استریل‌شده کار می‌کند. افزون بر این، همهٔ خروجی‌های عامل باید پاک‌سازی شوند تا از تزریق درخواست و تعامل‌های یاغی با رابط کاربری جلوگیری شود.

```
def resolve_context(template_str, override_state=None):
    """Replace [[VARIABLE_NAME]] with runtime state or env values."""
    state = override_state or {}

    def replacement(match):
        var = match.group(1).strip()
        if state.get(var) is not None:      # 1. runtime override
            return str(state[var])
        if os.environ.get(var) is not None: # 2. validated env var
            return os.environ[var]
        return match.group(0)              # 3. leave unresolved: no silent fa

    return re.sub(r'\[\[([^\]]+)\]\]', replacement, template_str)
```

این ابزار باید مستقیم در خط لولهٔ اجرای عامل به‌عنوان گام اعتبارسنجی سیم‌کشی شود: فراخوان‌های ورودی ابزار را پیش از اجرا رهگیری کنید تا همهٔ رشته‌های تزریق‌شده پویا استریل شوند. با اعمال این مرز، هر تلاش عامل برای اجرای کنشی – مثل فرستادن ایمیل یا پرس‌وجوی یک منبع ابری – رهگیری می‌شود و موتور، جانشین‌های عمومی را امن و بی‌صدا به دارایی‌های آزمونی مجاز ترجمه می‌کند. نتیجه: نیاز به سخت‌کد کردن اطلاعات حساس در مجموعه‌آزمون‌ها یا درخواست‌های سامانه کاملاً از بین می‌رود.

۱۲. جمع‌بندی دوره

جلسه	پرسش محوری	پاسخی که ساختیم
۱	چه چیزی واقعاً عوض شده؟	گذار از نحو به قصد؛ طیف کدنویسی شهودی تا مهندسی عامل‌محور؛ و اینکه عامل = مدل + مهار .
۲	عامل چطور با جهان حرف می‌زند؟	پروتکل‌های باز به جای پوشش‌های سفارشی: ابزار، همکاری عامل با عامل، رابط کاربری مولد، و تجارت خودگردان.
۳	عامل چطور می‌داند «چگونه»؟	مهارت به‌عنوان نخستین حافظهٔ رویه‌ای باورپذیر، با افشای تدریجی و ارزیابی سخت‌گیرانه.
۴	چه چیزی خراب می‌شود و چطور می‌سنجیم؟	هفت ستون امنیت، و هفت بُعد ارزیابی – دو محور مستقل اعتماد.
۵	چطور این‌ها را به تولید می‌رسانیم؟	مشخصات به‌عنوان منبع حقیقت، فرایند تیمی بازطراحی‌شده، و شبکهٔ ایمنی اعتماد صفر.

در کمتر از یک سال، چرخهٔ توسعهٔ نرم‌افزار به‌شکل چشمگیری سریع‌تر شده است. اما آن سرعت جابه‌جایی مهمی را آشکار کرد: هوش مصنوعی گلوگاه **تولید کد** را حذف کرده و قید را به پایین‌دست برده، به انسان‌هایی که باید این خروجی را بازبینی، آزمون و یکپارچه کنند. این یک **بار شناختی مشترک** است: انسان‌ها معمارانی‌اند که مشخصات آزمون، مشخصات یکپارچگی و نقشه‌های عملیاتی را می‌نویسند، در حالی که هوش مصنوعی کار سنگین نوشتن کد آزمون، انجام یکپارچه‌سازی و مدیریت جزئیات ریز عملیاتی را بر عهده می‌گیرد.

درخواست‌های بهتر و مدل‌های سریع‌تر به‌تنهایی گلوگاه یکپارچگی را حل نمی‌کنند. موفقیت به تحول پویایی تیم، پالایش همکاری با عامل‌ها، و تعیین مرزهای سخت‌گیرانه برای ابزارهایی بستگی دارد که هرگز نمی‌خواهند. چالش از تولید صرف کد، به هماهنگ‌کردن سامانه‌هایی منتقل شده که کار را راستی‌آزمایی، یکپارچه و مستقر می‌کنند.

۱۳. خودآزمایی

۱. «توهم سرعت» را در یک جمله توضیح دهید و بگویید در تیم شما چطور بروز می‌کند.

2. اگر مشخصات پروژه شما فردا از بین برود، چقدر از کدپایه‌تان قابل بازتولید است؟ این عدد چه چیزی درباره کیفیت مشخصات شما می‌گوید؟
3. یک نیازمندی مبهم از پروژه خودتان را بردارید و به سه سناریوی «با فرض / وقتی / آنگاه» تبدیل کنید.
4. در پروژه شما، چه چیزی باید در پوشه مشخصات باشد، چه چیزی در مهارت‌ها، و چه چیزی در درخواست سامانه؟
5. آخرین باری که با عامل اشکالی را رفع کردید، درخواست‌تان علامت‌محور بود یا شاهدمحور؟
6. کدام یک از سه دسته شکست فرایندی (تعارض ادغام، گره‌خوردگی بازبینی، پاره‌پاره‌شدن زمینه) بیشترین هزینه را به تیم شما تحمیل می‌کند؟
7. تیم شما به کدام لایه بازبین خودکار نیاز دارد؟ سه پرسش تصمیم‌گیری را برای خودتان پاسخ دهید.
8. آیا در تیم شما نشانه‌های خستگی تأیید دیده می‌شود؟ چه مرزی می‌توانید همین هفته بگذارید؟
9. داستان پنجاه ایمیل را بازخوانی کنید: کدام یک از پنج لایه شبکه ایمنی می‌توانست جلوییش را بگیرد، و در کدام نقطه؟
10. یک نمونه بیاورید که در آن ابزار مجاز است اما نحوه استفاده باید مسدود شود. این قاعده را به زبان طبیعی بنویسید.

منبع: این جزوه خلاصه و بازنویسی آموزشی مقاله Spec-Driven Production Grade Development in the Age of Vibe Coding نوشته لی بونسترا است (مجموعه مقالات عامل‌ها، می ۲۰۲۶). ترجمه کامل فارسی در همین پوشه در دسترس است.
